



# Production Readiness Assessment

A concise technical rating and remediation handover based on the WatchWDS code supplied by Faruk on 9 August 2026.

3.5/10

PRODUCTION READINESS

Original supplied ZIP

7.0/10

FEATURE-RICH PROTOTYPE

Product and feature view

4.2/10

STRIPE CANDIDATE

Safer staging package

**Good prototype. Unsafe production platform.**

WatchWDS is a substantial, ambitious platform with matches, subscriptions, PPV, creator tools, administration, blogs and community features. The main problem is not the feature set. Several controls protecting accounts, payments and paid footage are not yet enforced securely.

| ASSESSMENT BASIS                                                                                                                                                                  | CURRENT DECISION                                                                                                                                                        |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Static source-code review, clean build checks, dependency review and comparison with the integrated Stripe staging candidate. This is not a penetration test of the live website. | Do not upload either package directly to production. Faruk should correct the P0 controls in a private staging branch and return evidence for independent verification. |

Prepared for: Faruk | Assessment date: 10 August 2026 | Classification: Internal technical handover

## Where the current code stands

The original package is rated as delivered. The Stripe candidate represents the later test-locked integration and is not a production release.

| Assessment area                 | Faruk's ZIP | Stripe staging candidate | Change    |
|---------------------------------|-------------|--------------------------|-----------|
| Product and interface structure | 7/10        | 7/10                     | No change |
| Feature coverage                | 7/10        | 7/10                     | No change |
| Functional reliability          | 4/10        | 4.5/10                   | +0.5      |
| Authentication and security     | 1/10        | 2.5/10                   | +1.5      |
| PPV and paywall protection      | 1/10        | 1.5/10                   | +0.5      |
| Payments and reconciliation     | 2/10        | 5/10                     | +3.0      |
| Code maintainability            | 4/10        | 4.5/10                   | +0.5      |
| Testing and release evidence    | 2/10        | 4/10                     | +2.0      |
| Performance                     | 4/10        | 4/10                     | No change |
| SEO                             | 3/10        | 3/10                     | No change |
| Privacy and accessibility       | 3/10        | 3/10                     | No change |
| Overall                         | 3.5/10      | 4.2/10                   | +0.7      |

|                                |                               |                                       |                                     |
|--------------------------------|-------------------------------|---------------------------------------|-------------------------------------|
| 0-3.9<br>Unsafe for production | 4-5.9<br>Private staging only | 6-7.9<br>Controlled release candidate | 8-10<br>Strong production candidate |
|--------------------------------|-------------------------------|---------------------------------------|-------------------------------------|

The Stripe candidate materially improves payment handling, but it does not repair the inherited authentication, paywall, stored-XSS or sensitive-settings issues. Its 4.2/10 score therefore remains a staging score, not deployment approval.

# The eight most damaging issues

Each item below is a P0 gate because it can affect identity, privilege, paid access, payment integrity or session safety.

1

**Google authentication can be impersonated**

The submitted login identity is not proven strongly enough on the server, allowing a forged account claim and possible administrator impersonation.

Status: Unresolved in both reviewed packages

2

**Protected profile fields can be changed**

Profile update handling does not strictly allowlist ordinary fields, so role, balance or other privileged account attributes may be altered.

Status: Unresolved in both reviewed packages

3

**PPV playback data is exposed publicly**

Public match responses can include stream or embed information before a server-side entitlement decision has approved the viewer.

Status: Unresolved in both reviewed packages

4

**The entitlement check always approves access**

The current access-control logic does not reliably bind a paid order or subscription to the authenticated user and requested match.

Status: Unresolved in both reviewed packages

5

**Stored HTML can execute JavaScript**

User- or admin-supplied rich content can be rendered without sufficient sanitisation, creating a stored-XSS route capable of session theft.

Status: Unresolved in both reviewed packages

6

**Payment paths can trust browser input or fail open**

Some routes accept client-supplied prices, mock success or fallback behavior. The Stripe candidate fixes a meaningful subset, but not every non-Stripe path.

Status: Partially improved in the Stripe candidate

7

**Public settings can expose sensitive configuration**

Configuration responses and browser-bundled variables need explicit public allowlists so private keys, tokens or internal settings cannot leak.

Status: Unresolved in both reviewed packages

8

**Testing does not cover the whole security boundary**

The original package has little meaningful automated protection. The candidate adds 19 Stripe-focused tests, but lacks full authentication, paywall and XSS regression coverage.

Status: Improved, but still incomplete

Faruk has built a valuable product foundation. The required work is now to convert assumed controls into server-enforced, test-proven controls. Feature expansion should pause until these eight launch blockers are closed.

## 03 REQUIRED REMEDIATION HANDOVER

# What Faruk should do next

Complete these items in a private development or staging branch. Do not deploy the supplied ZIP or the integrated Stripe candidate directly to the public production site.

- 1 Replace the Google login shortcut**  
Verify an authentic Google ID token or OAuth code on the server, bind it to the expected client, and reject any login based only on a submitted email address.
- 2 Lock profile updates to an allowlist**  
Accept only ordinary user-editable fields. Block role, wallet, balance, privilege, verification and administrative fields regardless of browser input.
- 3 Enforce PPV access entirely on the server**  
Return no stream URL, embed HTML, playback ID or token until the authenticated user has an active match-specific entitlement.
- 4 Replace the always-allow entitlement logic**  
Bind access to completed, non-refunded orders or valid subscriptions; fail closed when payment state, user identity or match mapping is uncertain.
- 5 Remove stored-XSS paths**  
Sanitise rich text with a strict server-side policy, encode output by context, add an effective Content Security Policy, and protect session cookies.
- 6 Finish payment integrity controls**  
Use server-authoritative product pricing, signed raw-body webhooks, idempotent state changes, atomic order-entitlement writes and no mock or fallback success path.
- 7 Separate secrets from public configuration**  
Expose only an explicit public settings allowlist. Keep provider secrets in a restricted staging environment and scan builds and archives for accidental leakage.
- 8 Add release-blocking regression tests**  
Cover authentication forgery, privilege escalation, unauthorised PPV access, refunded access, stored XSS, public settings leakage and payment failure/retry behavior.

| FARUK MUST RETURN                | PASS CONDITION                                                                         |
|----------------------------------|----------------------------------------------------------------------------------------|
| Commit or pull-request reference | All P0 changes are traceable in the canonical private branch.                          |
| Automated test output            | Authentication, authorisation, PPV, XSS and payments pass with negative-path coverage. |
| Security and dependency evidence | No secrets in source/build and no unresolved high or critical dependency advisories.   |
| Staging release evidence         | Private staging only; no live keys, production database changes or real payments.      |

Expected progression: closing and independently verifying the P0 controls could move WatchWDS into the 6.5-7/10 range. Full payment recovery, performance, SEO, privacy, accessibility and end-to-end testing could support an 8/10 or higher assessment. These are targets, not guarantees.